TEMPLATE, SUBJECT TO LEGAL REVIEW AND SIGNATURE

Data Processing Agreement

AbrahamMoses private workspaces, Deep Analysis and Decision Passport

Template version 1.0, 21 October 2026. Square brackets mark what the parties complete.

Parties

Controller	[Customer's legal name], [registration number], [address] (the "Customer"), acting as controller.
Processor	Sagolik, Halmstad, Sweden (the "Processor"), the operator of AbrahamMoses, acting as processor. Sagolik is not VAT-registered.

1. Background and scope

1.1 The Customer uses AbrahamMoses under the Terms of Sale for a Decision Twin pilot or another written agreement between the parties (the "Main Agreement"). In doing so the Processor processes personal data on the Customer's behalf.

1.2 This Agreement applies to all personal data the Processor processes for the Customer under the Main Agreement, as described in Annex 1. It forms part of the Main Agreement. If they conflict on the processing of personal data, this Agreement prevails.

1.3 Terms such as "personal data", "processing", "controller", "processor", "data subject" and "personal data breach" have the meanings given in Regulation (EU) 2016/679 (the "GDPR").

2. Processing on documented instructions (Art. 28(3)(a))

2.1 The Processor processes the personal data only on the Customer's documented instructions, including with regard to transfers to a third country, unless EU or Member State law requires otherwise; in that case the Processor informs the Customer of that legal requirement before processing, unless the law prohibits it.

2.2 The Customer's instructions are this Agreement, the Main Agreement and the Customer's use of the service's own functions (importing, analysing, reviewing, issuing and revoking). Further instructions are given in writing.

2.3 The Processor informs the Customer without delay if, in its opinion, an instruction infringes the GDPR or other data protection law.

2.4 The Customer is responsible for the lawfulness of the processing it instructs, including having a lawful basis for uploading personal data to the service.

3. Confidentiality (Art. 28(3)(b))

3.1 The Processor ensures that every person it authorises to process the personal data is bound by confidentiality. At the date of this template the only such person is the Processor's operator.

4. Security of processing (Art. 28(3)(c), Art. 32)

4.1 The Processor implements the technical and organisational measures described in Annex 2. It may change them, provided the overall level of protection is not reduced.

4.2 The Customer has reviewed Annex 2, including its statement of what is not in place (no certification, no external penetration test, no backups or point-in-time recovery, a single operator), and is responsible for deciding whether the measures are appropriate for the personal data it chooses to upload.

5. Sub-processors (Art. 28(2), 28(4), 28(3)(d))

5.1 The Customer gives general written authorisation for the Processor to engage the sub-processors listed in Annex 3.

5.2 The Processor gives the Customer at least 30 days' written notice before adding or replacing a sub-processor. The Customer may object on reasonable data-protection grounds within that period; if the parties cannot resolve the objection, the Customer may terminate the affected service and receive a pro-rata refund of prepaid fees for it.

5.3 The Processor imposes on each sub-processor data protection obligations that provide sufficient guarantees within the meaning of Article 28(4) GDPR, through that sub-processor's published data processing terms, and remains responsible to the Customer for its sub-processors' performance.

6. Assistance with data subjects' rights (Art. 28(3)(e))

6.1 Taking into account the nature of the processing, the Processor assists the Customer by appropriate technical and organisational measures, insofar as possible, in responding to requests from data subjects. The Processor forwards to the Customer without undue delay any request it receives that concerns the Customer's data and does not answer it itself unless the Customer instructs it to.

7. Personal data breaches and other assistance (Art. 28(3)(f), Arts. 32–36)

7.1 The Processor notifies the Customer without undue delay, and in any event within 48 hours, after becoming aware of a personal data breach affecting the Customer's personal data. The notice describes, as far as then known, the nature of the breach, the categories and approximate number of data subjects and records concerned, the likely consequences and the measures taken or proposed. Information not available at first is provided in phases as it becomes available.

7.2 Notices are sent by email to the Customer's contact named in the signature block below.

7.3 The Processor assists the Customer, taking into account the nature of the processing and the information available to it, with the Customer's obligations on security, breach notification, data protection impact assessments and prior consultation.

8. Deletion or return at the end of the services (Art. 28(3)(g))

8.1 At the end of the services, at the Customer's choice, the Processor returns the Customer's personal data in a machine-readable format and deletes it, within 30 days, unless EU or Member State law requires storage. The Processor confirms the deletion in writing.

8.2 The application keeps workspace records append-only by design, so that no user can alter or remove the evidence trail; deletion at the end of the services is therefore carried out by the Processor's operator with project-administrator access to the database.

8.3 Entries in the public Decision Passport registry and revocation list contain hashes, a key identifier, the workspace identifier and timestamps, but no document content and no names or email addresses. They are kept permanently so that issued passports stay verifiable. The Customer should choose a workspace identifier that does not identify a person.

9. Information and audits (Art. 28(3)(h))

9.1 The Processor makes available to the Customer the information necessary to demonstrate compliance with Article 28 GDPR, including the security description on the AbrahamMoses Trust pages and answers to reasonable written questions.

9.2 The Processor allows for and contributes to audits, including inspections, by the Customer or an auditor it mandates who is bound by confidentiality, on at least 30 days' written notice, during normal business hours, no more than once a year unless a personal data breach or a supervisory authority requires otherwise. Each party bears its own costs.

9.3 The Processor holds no ISO/IEC 27001 certification or SOC 2 report and has not commissioned an external penetration test. It does not offer these as evidence.

10. Transfers outside the EEA (Chapter V GDPR)

10.1 The hosting provider's server functions run in Stockholm, Sweden (EU), Vercel region arn1, and the workspace database is located in the EEA (eur3). Some sub-processors in Annex 3 process personal data in the United States: Firebase Authentication (account records) and, when the Deep Analysis AI layer is used, OpenAI. The hosting provider and Stripe are also established in or have affiliates in the United States.

10.2 Such transfers take place only under an adequacy decision of the European Commission, including the EU-U.S. Data Privacy Framework where the recipient is certified, or under the European Commission's standard contractual clauses incorporated in the sub-processor's data processing terms.

11. Liability

11.1 Each party's liability under this Agreement is governed by the Main Agreement, without prejudice to Article 82 GDPR as regards data subjects.

12. Term

12.1 This Agreement applies from signature for as long as the Processor processes personal data on the Customer's behalf, and Clause 8 survives until deletion or return is complete.

13. Governing law and disputes

13.1 This Agreement is governed by Swedish law. Disputes are settled by the Swedish courts.

Annex 1. Details of the processing

Subject matter	Provision of AbrahamMoses private workspaces, the Decision Room, Deep Analysis and Decision Passport issuing under the Main Agreement.
Duration	The term of the Main Agreement, and the deletion period in Clause 8.
Nature and purpose	Storage of documents the Customer's users import; analysis of those documents (rule-based, and with the AI layer when a user switches it on); recording of decisions, reviews, approvals and passport issuance with an audit trail; verification of passports.
Categories of data subjects	The Customer's authorised users; persons named in the documents the Customer's users upload (for example counterparties, borrowers, employees or signatories).
Types of personal data	Users: email address, account identifier, sign-in method and, for Google sign-in, name and picture; the role and organisation a user gives; actions recorded in the audit trail with time. Documents: whatever personal data the Customer's documents contain (names, contact details, financial or contractual information).
Special categories	Not intended. The Customer does not upload special categories of personal data (Article 9 GDPR) or data on criminal convictions (Article 10) unless the parties have agreed so in writing beforehand.
Retention	Workspace records: until the end of the services and the deletion period in Clause 8. Deep Analysis documents and reports outside a workspace are not stored. Hosting provider logs: the provider's operational log period.

Annex 2. Technical and organisational measures

Access control	Sign-in with Google or a verified email address (Firebase Authentication). Workspace membership and editor roles are set only by the Processor's operator; no user or server route can grant them. Every database write is checked by the Firestore security rules, deny-by-default.
Tenant isolation	Each workspace is a separate tenant in the database. The security rules allow reads and writes only to that workspace's members.
No administrator key on the server	The application servers hold no database administrator credential. Server routes act with the signed-in user's own token, so they can never do more than the user could do directly.
Two-person review	Decisions and passports are approved only by a workspace editor who is not the proposer, enforced by the security rules and the server.
Integrity	Imported documents are immutable and hashed (SHA-256) per passage. Decision Passports are signed with Ed25519 on the server; the private key exists only in the hosting provider's encrypted environment configuration and is never logged or returned.
Audit trail	Every workspace change is written with its audit event in one atomic batch; audit events cannot be edited or deleted through the application.
Encryption	In transit: TLS 1.2 or 1.3 only, HSTS for two years. At rest: the database is

	encrypted by Google by default.
Data minimisation	Deep Analysis outside a workspace stores neither the document nor the report. AI requests are sent with provider-side storage turned off. Security logs record a one-way hash of the IP address, never request text.
Application security	Content Security Policy, frame protection and other security headers on every page; request-size limits and rate limits on write routes; automated security regression tests, browser tests and database-rule tests in CI on every change.
Not in place	No ISO/IEC 27001 certification, no SOC 2 report, no external penetration test, no database backups or point-in-time recovery (delete protection on the database is enabled), and a single operator without a second person on call.

Annex 3. Authorised sub-processors

SUB-PROCESSOR	PURPOSE	LOCATION
Vercel (Vercel Inc., United States)	Hosting: serves every page and runs the server functions (API routes, Deep Analysis, passport issuing).	Server functions: Stockholm, Sweden (EU), Vercel region arn1. Static pages: Vercel's global edge network.
Google Firebase (Google LLC (Firebase Authentication) and Google Cloud (Cloud Firestore))	Accounts and sign-in (Firebase Authentication), including verification and password-reset emails; the database for private workspaces, Decision Passport drafts and registry, audit events and Deep Analysis profiles (Cloud Firestore).	Firebase Authentication: United States. Cloud Firestore: eur3, multi-region Europe: Belgium (europe-west1) and the Netherlands (europe-west4), witness in Finland (europe-north1).
OpenAI (OpenAI Ireland Ltd. (the contracting party for customers in the EEA), processing with its US affiliates)	The optional AI layer of Deep Analysis: produces AI findings, each of which must quote the document verbatim or is discarded.	United States.
Stripe (Stripe Payments Europe, Limited, Ireland)	Payment of pilot reservations on Stripe's own checkout page; invoices and receipts.	European Union and United States (Stripe's infrastructure).

Signatures

For the Customer: name, title, date, signature; contact for breach notices	
For the Processor (Sagolik): name, date, signature	

This template has not been reviewed by a lawyer. It binds neither party until signed.